Implementing Security Features and Governance / Administration Practices in Zoho Creator

1. AIM

To design and implement a layered, defence-in-depth security architecture and a structured governance and administration framework in Zoho Creator, so that every Creator application enforces the principle of least privilege through Role-Based Access Control (RBAC), protects data in transit and at rest, authenticates identities through Multi-Factor Authentication (MFA) and Single Sign-On (SSO), maintains an immutable audit trail, and follows a controlled Software Development Life Cycle (SDLC) across the Development, Stage and Production environments, thereby preserving the Confidentiality, Integrity and Availability (CIA triad) of organisational data and meeting regulatory requirements such as GDPR and ISO 27001.

2. PROCEDURE

Step 1: Define the governance baseline and data classification

Identify the application owner, Super Admin, Admins, Developers and end-user personas (Employee, Manager, Customer or Portal user). Classify data as Public, Internal, Confidential or Restricted. Map each class to the Forms, Reports, Pages and Fields that hold it. Document this as an Access Control Matrix that drives all later configuration.

Step 2: Harden authentication at the account and organisation level

Open Zoho Accounts and then Security. Enforce Two-Factor / Multi-Factor Authentication (Zoho OneAuth, TOTP or push notification). Configure SAML 2.0 based SSO with the corporate Identity Provider (such as Azure AD or Okta). Define a strong password policy (length, complexity, expiry, history), session timeout and concurrent-session control, and enable IP Restriction by listing Allowed IP addresses or ranges so that logins are accepted only from trusted networks.

Step 3: Create Profiles, Roles and User Groups (RBAC)

Go to Settings, then Users and Control. Create custom Profiles in addition to the default Administrator and Developer profiles. For each Profile, set granular Permissions on every Form (Create, View, Edit, Delete, Import, Export, Bulk Edit), Report and Page. Build a Role hierarchy so that a superior role can view records owned by its subordinates, and organise users into User Groups for bulk assignment. Apply the principle of least privilege so that no one is granted more than the job requires.

Step 4: Apply Field-Level and Record-Level Security

In Profile settings, use Field Permissions to set sensitive fields (for example salary, Aadhaar or PAN number, bank details) to Hidden or Read-only. For record-level security, define Report Criteria and Permission Filters (for example Added_User = zoho.loginuser) so that each user sees only the records they own or are authorised to see. Use Deluge conditions in Page and Report logic for any dynamic restrictions that criteria cannot express.

Step 5: Configure application sharing and Portal access

Use the Share option to invite Users and Groups with the correct Profile, and avoid sharing through a public Permalink for sensitive modules. For external stakeholders, publish a Zoho Creator Portal with its own authentication (Zoho login, Google, Microsoft or Custom SAML) and portal-specific Profiles. Prefer a Private Link with an encrypted key over a Public Link, set the allowed embed domains, and bind the application to a Custom Domain secured with an SSL / TLS certificate.

Step 6: Enforce data protection (encryption and residency)

Verify that data in transit uses TLS 1.2 or higher and that data at rest is protected with AES-256 encryption. Enable Field Encryption for highly confidential fields, and mask values with the Decimal / Number and Single-line display options where required. Choose the correct Data Centre region (.com, .eu, .in, .com.au, .jp) to meet data-residency and sovereignty rules.

Step 7: Secure Deluge scripting and API integrations

Validate all inputs in the On Validate and On User Input workflow events, using Deluge functions such as isNull(), isBlank() and regex matching together with the cancel submit statement to reject malformed data and prevent injection. Never hard-code credentials, tokens or client secrets in Deluge scripts. Create Connections (OAuth 2.0) in Settings, then Connections, with minimum scopes, and call them through invokeurl. For the Zoho Creator REST API v2.1, issue OAuth tokens with narrow scopes such as ZohoCreator.form.CREATE or ZohoCreator.report.READ, and avoid public-key based API access.

Step 8: Establish change governance using Environments

Enable the Development, Stage and Production Environments. Build and modify only in Development, test and run User Acceptance Testing in Stage with sanitised data, and deploy to Production only after approval. Restrict Developer rights in Production, maintain a version history and release notes for every deployment, and use an Approval workflow for change requests.

Step 9: Enable auditing, logging and monitoring

Turn on the Audit Trail (Application Logs) so that record creation, modification, deletion, login, sharing and permission changes are captured with user, time stamp and IP address. Review the Login History, Deluge Execution Logs and Error Logs regularly. Configure workflow-based Email and Push alerts for suspicious actions such as bulk export or deletion, and schedule a periodic User Access Review to remove dormant or excess privileges.

Step 10: Configure backup, recovery and retention

Schedule automated Data Backups (daily, weekly or monthly), and store the exported .zip or .ds package for Disaster Recovery (DR) and Business Continuity Planning (BCP). Define a retention and archival policy, and test the Restore procedure periodically so that the Recovery Point Objective (RPO) and Recovery Time Objective (RTO) are met.

Step 11: Validate and document

Test every Profile with the Preview As / Login As feature, and attempt unauthorised access, URL tampering and privilege-escalation scenarios to confirm the controls hold. Record the final configuration, owners, review frequency and exceptions in a Security and Governance Policy document, and review it at fixed intervals.

3. WHAT WILL HAPPEN IF NOT DONE

If these security and governance practices are not implemented, the following risks arise for each control area:

Control Area	Consequence if not implemented
Authentication (MFA, SSO, IP Restriction)	Credential stuffing, phishing and brute-force attacks can succeed, giving attackers account takeover and unauthorised access from any network or location.

Control Area	Consequence if not implemented
RBAC (Profiles, Roles, Groups)	Privilege creep and horizontal or vertical privilege escalation occur; ordinary users can create, edit, delete or export data they should not touch, violating segregation of duties.
Field-Level and Record-Level Security	Personally Identifiable Information (PII) and financial data are exposed to unauthorised users, leading to data leakage, insider threat and loss of customer trust.
Sharing and Portal Settings	Public Permalinks and open Portals expose forms and reports to the internet, enabling data scraping, spam submissions and unauthenticated access.
Encryption and Data Residency	Sensitive data may be intercepted or read in plain form, and storing data in the wrong region breaches GDPR or local data-protection law, attracting legal penalties.
Deluge Validation and API Security	Injection, malformed or duplicate data corrupts data integrity; leaked tokens or hard-coded secrets allow external parties to misuse the Creator REST API.
Environment and Change Governance	Untested changes go live directly in Production, causing workflow failures, downtime, data corruption and no rollback path.
Audit Trail and Monitoring	Breaches and malicious edits remain undetected, there is no non-repudiation or forensic evidence, and compliance audits fail.
Backup and Recovery	Accidental deletion, ransomware or a faulty deployment causes permanent data loss with no ability to meet RPO and RTO, interrupting business continuity.

Overall, the organisation faces data breaches, regulatory non-compliance, financial and reputational loss, and an unmaintainable application landscape with no accountability.

4. RESULT

On implementing the above procedure, the Zoho Creator application achieves the following:

- Only authenticated and authorised users, from trusted networks and through SSO with MFA, can access the application.

- Access is strictly governed by Profiles, Roles, Field Permissions and record-level criteria, enforcing least privilege and segregation of duties.
- Data is protected in transit (TLS) and at rest (AES-256), and is stored in the compliant Data Centre region.
- Deluge scripts and API Connections are secured through input validation, OAuth 2.0 scopes and secret-free code.
- Changes move through Development, Stage and Production in a controlled and traceable manner, reducing downtime and defects.
- The Audit Trail provides complete accountability and non-repudiation, and supports compliance audits for GDPR and ISO 27001.
- Scheduled backups and a tested restore plan ensure data availability, resilience and business continuity.

Thus, security features and governance / administration practices were successfully implemented in Zoho Creator, resulting in a secure, compliant, auditable and well-governed low-code application environment.